

Homework #2

Requirement #3: Protecting Stored Account Data

Policy is to protect sensitive account data and all financial records and cardholder information must be securely stored at all times. Storing any sensitive data on local employee computers is not allowed. All sensitive information must be stored on our approved cloud-based remote server.

Procedures

Step 1: Data Storage Location

- Sensitive financial and cardholder data must be directly sent to the remote cloud server.
- No employee is allowed to download, store, or cache sensitive information on their personal computers, flash drives, or unauthorized devices.

Step 2: Data Retention and Disposal

- Company will keep sensitive account data only as long as necessary for legal, regulatory, and business purposes.
- Once the data is no longer needed, it must be securely deleted following proper procedures.

Step 3: Access Control

- Only employees who need access to sensitive information for their job will be given permission.
- Access will be managed using role-based access controls (RBAC).

Step 4: Encryption

- All sensitive data must be encrypted using standard methods like AES-256.
- Encryption keys will be carefully stored and only accessible by authorized staff.

Step 5: Monitoring and Auditing

- Will keep logs of who accesses sensitive data and monitor these logs regularly.
- Routine audits will be done to make sure everyone is following the policies.

Homework #2

Requirement #4: Protect Cardholder data with strong cryptography during transmission over open public networks.

Policy for requirement 4 is that all cardholder data that needs to be sent over public networks must be protected using strong encryption methods. The accounting services company committed to using secure protocols like TLS 1.2 or higher to keep the data safe while it is being transmitted.

Procedures

Step 1: Use of Strong Cryptography

- All sensitive data transmissions must use encryption protocols like TLS 1.2+ or IPSec.
- Older insecure protocols like SSL and early versions of TLS are strictly prohibited.

Step 2: Configuration of Devices and Networks

- All routers, switches, and network devices must be configured to prioritize secure encryption.
- Network Interface Cards (NICs) and wireless access points must support secure transmission standards.

Step 3: Certificate Management

- Digital certificates must be obtained from trusted Certificate Authorities and monitored for expiration.
- Renewal procedures must be in place to avoid downtime or exposure.

Step 4: Employee Training and Awareness

- Employees responsible for handling sensitive information must be trained in the basics of computer networking, including understanding protocols, encryption, and the risks of public networks.
- Security awareness sessions must be conducted.

Step 5: Testing, Monitoring and Incident Report

- Regular vulnerability scans and penetration tests will be conducted to ensure network security.
- Any detected security incidents must be reported immediately following the company's incident response plan.